

Threat Analysis Report

รายงานวิเคราะห์แคมเปญหลอกลวง
MrBeast Impersonation และ Discord
Spam (Scambling)

21/04/2026

TLP:CLEAR





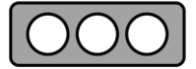
สารบัญ

บทสรุปสำหรับผู้บริหาร.....	3
การวิเคราะห์เชิงเทคนิค.....	4
Technique Tactics and Procedures (MITRE ATT&CK).....	7
Indicator of Compromise (IOCs).....	8
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	9
อ้างอิง (References).....	10



บทสรุปสำหรับผู้บริหาร

จากการตรวจสอบพบแคมเปญการหลอกลวงในลักษณะ Advance-Fee Scam ร่วมกับ Phishing ที่มีการแพร่ระบาดอย่างรวดเร็วผ่านแพลตฟอร์ม Discord และ X (Twitter) โดยแอบอ้างเป็น MrBeast ผู้โจมตีใช้บัญชีที่ถูกยึดครอง (Compromised Accounts) มาส่งข้อความสแปมเพื่อสร้างความน่าเชื่อถือ โดยมีเป้าหมายหลักคือการหลอกให้เหยื่อสมัครสมาชิกในเว็บไซต์พนันปลอม feastwin.com เพื่อรับเงินรางวัลปลอมมูลค่า \$2,500 ปฏิบัติการนี้มีความอันตรายเนื่องจากการขโมย Session Tokens ของเหยื่อเพื่อใช้ในการแพร่กระจายข้อความแบบ Worm-like และมีการเรียกเก็บเงิน "Verification Deposit" ก่อนการถอนเงิน ซึ่งส่งผลกระทบต่อทรัพย์สินและข้อมูลส่วนบุคคลของเหยื่อในวงกว้าง



การวิเคราะห์เชิงเทคนิค

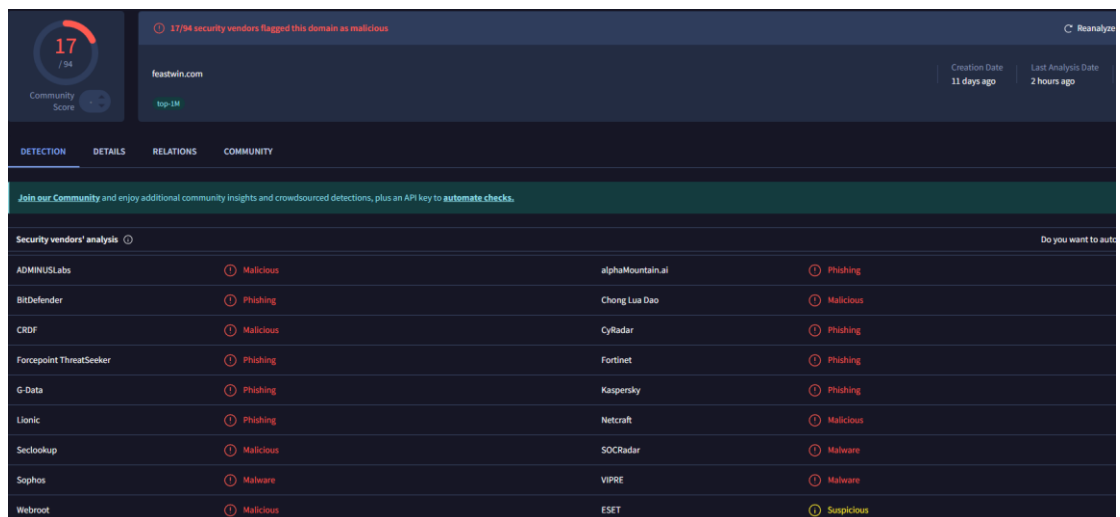
เมื่อช่วงปลายเดือนมีนาคม พ.ศ. 2569 แคมเปญการหลอกลวงในลักษณะ Advance-Fee Scam ร่วมกับ Phishing ที่มีการแพร่ระบาดอย่างรวดเร็วผ่านแพลตฟอร์ม Discord และ X (Twitter) โดยแอบอ้างเป็น MrBeast เป็นที่นิยมและระบาดอย่างแพร่หลายผ่านสื่อออนไลน์

เป้าหมาย: Token Theft , Crypto Stealer

ผู้ได้รับผลกระทบหลัก: ผู้ใช้งาน Discord และ X (Twitter)

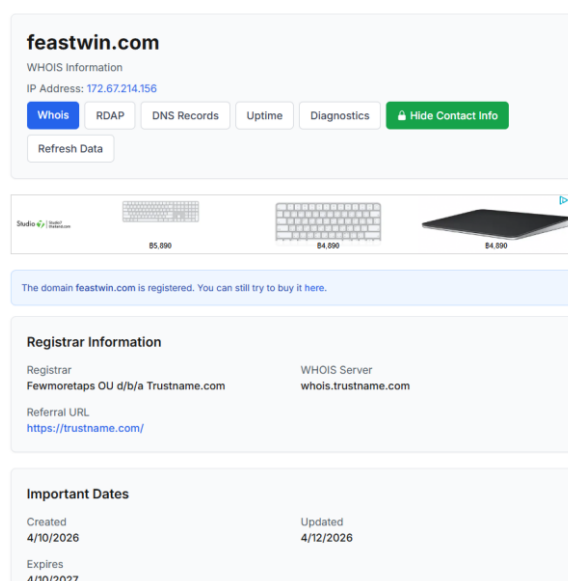
1. วิเคราะห์โครงสร้างพื้นฐาน (Infrastructure Analysis)

- โดเมนเป้าหมาย: feastwin.com จดทะเบียนเมื่อ 10 เมษายน 2569 มีคะแนนความเสี่ยง (Malicious Score) อยู่ที่ 17/94 โดยระบุว่าเป็น Phishing Website



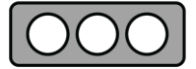
Security vendors' analysis	Malicious	Phishing	Malware	Suspicious
ADMINUSLabs	Malicious	Phishing		
BitDefender	Phishing	Malicious		
CRDF	Malicious	Phishing		
Forcepoint ThreatSeeker	Phishing	Phishing		
G-DATA	Phishing	Phishing		
Lionic	Phishing	Malicious		
Seclookup	Malicious	Malware		
Sophos	Malware	Malware		
Webroot	Malicious	Suspicious		

ภาพที่ 1 Malicious Score จาก VirusTotal

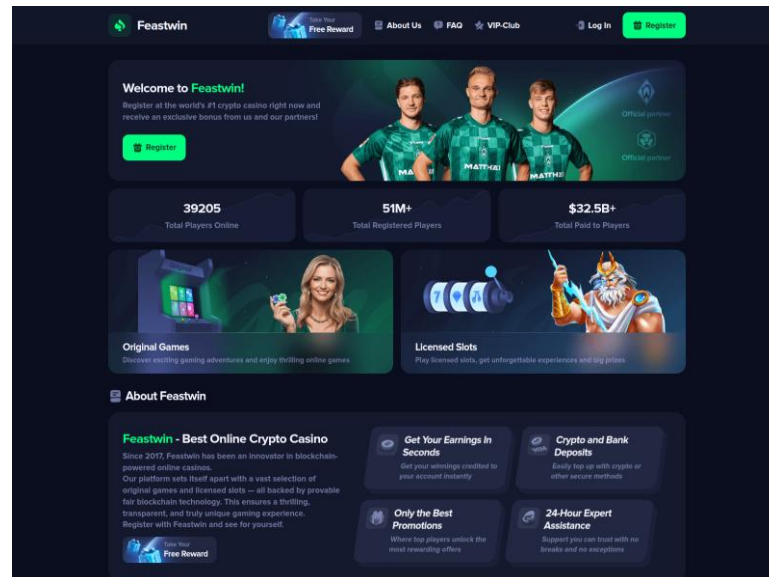


feastwin.com	
WHOIS Information	
IP Address: 172.67.214.156	
Whois	RDAP
DNS Records	Uptime
Diagnostics	Hide Contact Info
Refresh Data	
The domain feastwin.com is registered. You can still try to buy it here.	
Registrar Information	
Registrar	WHOIS Server
Fewmoretaps OU d/b/a Trustname.com	whois.trustname.com
Referral URL	
https://trustname.com/	
Important Dates	
Created	Updated
4/10/2026	4/12/2026
Expires	
4/10/2027	

ภาพที่ 2 ข้อมูล Domain จาก WHOIS



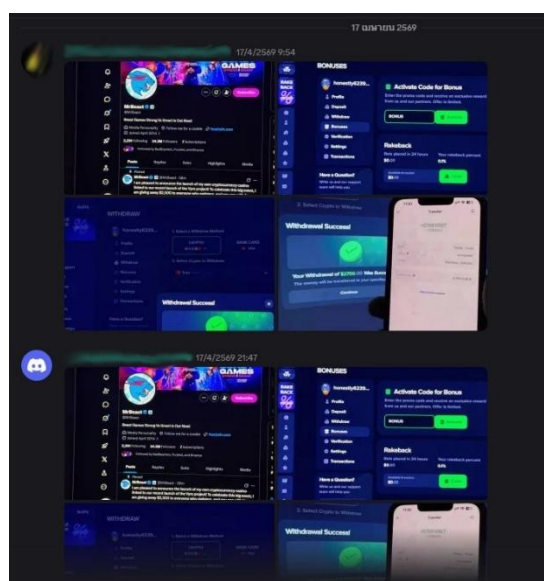
- กลไกการหลอกลวง: ใช้ภาพลักษณ์ของโครงการ "Beast Games" และ "Vyro Project" มาเป็นตัวล่อ พร้อมแสดงภาพความสำเร็จในการถอนเงิน (Withdrawal Success) ปลอมเพื่อสร้างความมั่นใจแก่เหยื่อ



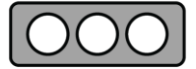
ภาพที่ 3 รูปภาพ Screenshot จาก URLscan.io

2. กลไกการขโมยข้อมูล (Token Hijacking)

- Initial Access: เข้าถึงผ่านบัญชี Discord เดิมที่โดน Compromised เพื่อส่งต่อลิงก์
- Session Theft: เว็บไซต์แอบอ้างสิทธิ์ผ่านระบบ Discord OAuth2 หรือใช้สคริปต์เพื่อดึง Access Token จาก Browser ของเหยื่อ ทำให้ผู้โจมตีเข้าควบคุมบัญชีได้โดยไม่ต้องมี Password หรือ MFA

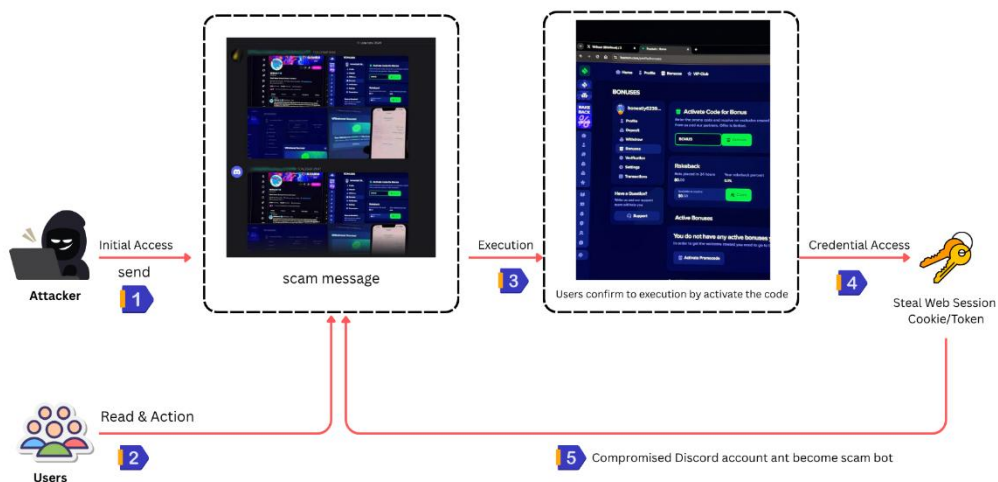


ภาพที่ 4 Discord Account ที่ถูก Compromised ส่งต่อลิงก์เพื่อขยายผลกระทบ



Attack Flow

- 1. Initial Access (การเข้าถึงระบบ):** ผู้โจมตีใช้บัญชี Discord ที่ถูกยึดครอง (Compromised Account) จากเหยื่อรายก่อนหน้า ส่งข้อความสแปมในลักษณะ Spearphishing ไปยังกลุ่มเป้าหมายหรือผู้ติดต่อส่วนตัว เพื่อสร้างความน่าเชื่อถือ
- 2. Read & Action (การตอบสนองของเหยื่อ):** เหยื่อที่ได้รับข้อความจะพบกับตัวล่อ (Lure) ที่แอบอ้างเป็น MrBeast และโครงการ Vyro Project พร้อมสัญญาว่าจะแจกเงินรางวัล
- 3. Execution (การเรียกใช้งาน):** เมื่อเหยื่อคลิกลิงก์ไปยังเว็บไซต์ feastwin.com ระบบจะหลอกให้เหยื่อสมัครสมาชิกและกรอกรหัส "BONUS" เพื่อยืนยันการรับรางวัล
- 4. Credential Access (การขโมยข้อมูล):** ในขั้นตอนการสมัครหรือยืนยันตัวตน เว็บไซต์จะใช้กลไก Discord OAuth2 หรือสคริปต์อันตรายเพื่อทำการขโมย Session Cookie หรือ Access Token ของเหยื่อโดยที่เหยื่อไม่รู้ตัว
- 5. Propagation (การแพร่กระจาย):** เมื่อผู้โจมตีได้รับ Token จะสามารถเข้าควบคุมบัญชี Discord ของเหยื่อได้โดยสมบูรณ์ และสั่งการให้บัญชีนั้นกลายเป็นบอทสแปมเพื่อส่งข้อความหลอกลวงต่อไปยังเหยื่อรายใหม่ เป็นวงจรต่อเนื่อง (Worm-like spread)



ภาพที่ 5 Attack Flow



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1566.003	Phishing: Spearphishing Service (Discord DM)
Execution	T1204.001	User Execution: Malicious Link
Credential Access	T1539	Steal Web Session Cookie/Token



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

File Names:

feastwin.com

File Hash

(Crypto Stealer)

d96d0f7875405d500e767ca06e45407d2b742806b6f62ae04e26ac3904a2c50c



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตรวจสอบ Logs ของ DNS และ Web Proxy สำหรับการเข้าถึงโดเมน feastwin.com
- เฝ้าระวังพฤติกรรมกรรมการส่งข้อความจำนวนมากผิดปกติจากบัญชีในองค์กรผ่าน Discord

การป้องกัน (Prevention)

- บล็อกการเข้าถึงโดเมนในเครือข่ายหลอกลวง (Blacklisting)
- สร้างความตระหนักรู้ (Security Awareness) เรื่องการแจกเงินปลอมและการขโมย Token

การรับมือ (Response)

- หากพบผู้ติดเชื่อ ให้รีบทำการ Reset Password และ Revoke Authorized Apps ใน Discord ทันที
- ตรวจสอบรายการธุรกรรม Crypto (ถ้ามี) และแจ้งความดำเนินคดีตามขั้นตอนของหน่วยงานที่เกี่ยวข้อง



อ้างอิง (References)

1. VirusTotal

<https://www.virustotal.com/gui/domain/feastwin.com/>

<https://www.virustotal.com/gui/file/d96d0f7875405d500e767ca06e45407d2b742806b6f62ae04e26ac3904a2c50c/detection>

2. WHOIS

<https://who.is/whois/feastwin.com>

3. URLscan.io

<https://urlscan.io/result/019dae40-74fa-72fe-b5bf-fb6374e92f72/>

4. Discord



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://forms.gle/we87Pq3TUtWzsF536>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th